

AF - 20250527

Con FTK Imager descargamos

- /root/\$MFT <-- descargamos ese ultimo fichero
- /root /\$Extend / \$UsnJrnl/ \$J <-- Descargamos ese ultimo fichero

Si en CMD ponemos dir /r podemos ver los ficheros "ocultos" como por ejemplo

```
"uca.txt:oculto.txt"
```

Pista para el Análisis:

usando " type C:\Windows\System32\cmd.exe > uca.txt:oculto.exe " y haciendo uso de WMIC, podría hacer que al ejecutar el TXT se abra de fondo el CMD

FTK IMAGER-->

Para ver el registro de Windows vamos a:

/Windows/System32/config

Los ficheros más importantes a extraer de ahí son:

- SAM: Todo lo relacionado con usuarios locales de la máquina (los de dominio NO)
- SOFTWARE: Todo el sw que tenemos instalado
- SYSTEM: Configuraciones relacionadas con el sistema (huso horario, políticas, red...)
- SECURITY: Todas las políticas del equipo
- DEFAULT: Políticas por defecto del equipo
- DRIVERS: Lo que su nombre indica

Para extraer el fichero NTUSER.DAT hay que ir al directorio "C:/Users/(Usuario)" y extraerlo de cada usuario

Para leer estos tipos de ficheros hay 3 posibles programas:

1. RegistryExplorer

- Desplegamos "ROOT/ SAM/ Domains/ Accounts/" y hacemos click en Users
- Vemos ahí todos los usuarios, los logins fallidos, fecha de creación, último inicio de sesión, fecha de cambio de pass, fecha del último fallo de pass y fecha de expiración de la pass
- Si en la columna "EXPIRES" aparece "30/12/1899" es que nunca expira la pass

2. WRR de MiTeC

- Si se hace click en "SAM"

3. RegRipper

Para el registro SYSTEM, desde el WRR, vamos a:

- Network Configuration y vemos toda la configuración de tarjetas de red

- "Services and Drivers" para ver todos los servicios (por ejemplo, mirar que haya una ruta que no cuadre para el System32)
- "Windows Installation" para ver last boot, last shutdown (los tiempos en UTC) y machine name
- Para ver el huso horario, Raw Data> ControlSet001> TimeZoneInformation:
 - ActiveTimeBias vemos las horas a sumar/restar a UTC
 - TimeZoneKey te pone la zona, de donde podemos sacar si suma o resta (Pacific resta)
- Para ver el horario de verano o de invierno, ahí dentro ^, en StandardBias, si pone 000000 es invierno; si pone otra cosa, ese valor se lo restamos al ActiveTimeBias
- Para ver USBs que se han pinchado en el equipo, dentro de Raw Data buscamos la carpeta USB y usbstor

Para el registro SOFTWARE, desde el WRR, vamos a ver todo lo relacionado con la instalación de Windows:

- General:
 - Owner del equipo
 - Product ID
 - Product Key
 - Fecha de instalación
 - Directorio raíz
 - Release ID
 - Versiones del SO (Build lab)
- Installed Software:
 - Ver todos los software instalados (especial hincapié a los RDP x.ej: AnyDesk)

Para ver el NTUSER.DAT lo abrimos desde Registry Explorer, y veremos lo siguiente:

- En el cuadro de búsqueda buscamos las siguientes claves de registro:
 - "Run" para ver los mecanismos de persistencia
 - "Typed" y vemos "TypedPaths" para ver los directorios escritos en el buscador del Explorador y "TypedURLs" para lo mismo pero en Navegadores de Microsoft (i.e: Explorer)
 - "UserAssist" para ver los programas ejecutados por el usuario y el tiempo que han estado ejecutándose
 - "USB" para ver si tiene permitido el uso de dispositivos USB

Eventos

Para ver todos los eventos vamos a "/Windows/System32/winevt/Logs/"

Desde el FTK Imager vamos a ese directorio y extraemos todo el directorio "Logs"

Para verlo de forma ágil (y no usar la mierda del Visor de Eventos de Microsoft), usamos "Nirsoft EventLogViewer"

Al ejecutarlo, le damos al segundo icono y en esa ventana ponemos el path del directorio "Logs" extraído anteriormente

- Puede dar error 1287, porque la RAM esté embotada- OK y palante con lo que cargue

Para configurar la herramienta para que se vea bien las cosas vamos a Options y:

Una vez se cargue, hay que buscar los siguientes Event IDs: (Options> Advanced Options)

- **4624** - Todo lo relacionado con el login exitoso en el sistema (logins remotos, locales, en red, cacheado..)
 - Logon Information
 - Logon Type
 - 5 - Windows Service Logon
 - 2 - Login via Consola
 - 0 - Login local
 - 7 - Credenciales de desbloqueo de pantalla
 - 3 - Login a través de red <-- IMPORTANTE
 - 11 - Cacheadas
 - 10 - Remote Desktop <-- IMPORTANTE
- **4625** - Logins fallidos
 - Clave para identificar intentos de Fuerza Bruta
 - Failure Information
 - Failure Reason: Unknown user name or bad password
- **7045** - Creación de servicios
 - Nombres alfanumericos entre 7-8 caracteres
- **21** - (Channel: "Microsoft-Windows-TerminalServices")
 - RDP
- **22** - (Channel: "Microsoft-Windows-TerminalServices")
 - Arranques de sesión
- **4104** - PowerShell
 - Mirar los comandos que se han ido ejecutando
 - SharpHound.ps1 es un colector que te dice toda la info de los usuarios (Record ID: 120)
- **1149** - RDP
 - Muestra origen y con qué usuario se ha conectado
 - Tiene que acompañar al 21 y 22 para que sea malo

- **4720** - Creación de usuario (Channel: Security)
 - **1102** - Antiforenses
 - Si aparecen los canales Aplicación o Security implican un borrado de logs
 - **4726** - Borrado de un usuario
-

SYSMON

Aplicación que hashea los eventos del sistema para, por ejemplo, subirlo a VirusTotal y ver si son maliciosos o no

Para ver tema de los navegadores (appdata/ local/ google/ chrome/ userdata/ default) y exportamos HISTORY

Lo abrimos con un visor de bases de datos (DB Browser for SQLite) y vemos las tablas:

- downloads
- urls <-- Aquí hay un posible phishing como vector de entrada
- visited_links
- visits